AICS-201: AI Ethics, Governance and Legal Compliance Assessment

SecureFinance Africa — Integrated Case-Based Assessment

Individual practical assessment | Assignment 01 | Prepared using synthetic data only

Yawukal Melaku

Contents

Executive Summary 3
1. Introduction, Scope and Method 3
1.1 Case context and system boundaries 3
1.2 Method and evidence 4
2. Ethical Risk Identification and Stakeholder Impact 4
2.1 Algorithmic bias and unfair financial outcomes 4
2.2 Privacy, transparency and human agency 4
2.3 Security, reliability and accountability 5
3. Governance and Risk Management Using NIST AI RMF 5
3.1 Govern 5
3.2 Map 5
3.3 Measure 6
3.4 Manage 6
3.5 Risk-register findings 6
4. Legal and Ethical Compliance Assessment 6
4.1 Nigeria Data Protection Act 2023 6
4.2 EU Artificial Intelligence Act 7
4.3 UNESCO Recommendation on the Ethics of AI 8
4.4 OECD AI Principles 8
4.5 Consolidated compliance position 8
5. Synthetic Fairness and Explainability Assessment 8
5.1 Dataset and experimental design 8
5.2 Predictive performance 8
5.3 Group fairness results 9
5.4 Explainability results 9
5.5 Fairness and explainability conclusion 10
6. Integrated Controls, Monitoring and Deployment Recommendation 10
6.1 Required controls before any pilot 10
6.2 Ongoing monitoring 10

6.3 Deployment decision 10
7. Conclusion 11
References 11
Appendix A. Evidence Inventory 11

Executive Summary

This report evaluates the ethical, governance, legal, fairness and explainability considerations associated with SecureFinance Africa, a fictional AI-enabled financial platform proposed for an initial deployment in Nigeria. The proposed platform supports identity verification, fraud detection and automated financial risk assessment. These functions can improve operational efficiency and help identify suspicious activity, but they can also affect access to financial services, privacy, customer dignity and institutional trust. The system therefore requires lifecycle governance rather than a narrow assessment of model accuracy.

The assessment identifies ten principal risks: algorithmic bias; privacy and data protection; unfair financial decisions; insufficient transparency; inadequate human oversight; cybersecurity and adversarial attacks; model drift; third-party and supply-chain risk; identity-verification errors; and insufficient accountability and auditability. The risk register rates seven risks Critical and three High before controls. Based on the proposed controls and the register's scoring assumptions, six risks are rated Moderate and four remain High after controls. These residual ratings are estimates, not evidence that controls have already been implemented or tested.

A synthetic experiment was conducted using 1,000 generated applicant records, with 700 used for training and 300 for testing. Logistic regression achieved 68.33% accuracy, 69.26% precision, 89.42% recall and an F1-score of 78.06%. The measured demographic parity difference was 0.0041, equal opportunity difference 0.0133 and equalized odds difference 0.0411. These results are useful as a reproducible demonstration, but they do not establish fairness or suitability for real lending decisions. The dataset is synthetic, the test sample is limited, and the results depend on the assumptions used to generate it.

The recommended decision is to keep the system in a controlled research and validation environment. It should not autonomously approve, reject or restrict customers. Progress toward a limited pilot should require legal review, a Data Privacy Impact Assessment where required, representative and lawfully sourced validation data, documented human review and appeal processes, security testing, independent model validation, and approved monitoring and rollback procedures.

1. Introduction, Scope and Method

1.1 Case context and system boundaries

SecureFinance Africa is treated as a fictional organisation considering an AI platform for three distinct purposes: identity verification, financial-fraud detection and financial risk or

creditworthiness assessment. These functions must not be treated as one undifferentiated AI system. Their data inputs, intended purposes, affected individuals, error consequences and legal classifications may differ. For example, an identity-verification tool may compare a claimed identity with an identity document, while a creditworthiness model may influence access to a financial product. A fraud-detection model may flag suspicious activity for investigation without making a final customer decision.

This assessment assumes an initial Nigerian deployment and possible future international expansion. It assumes that personal and financial information may be processed. Whether biometric data is used, whether decisions are solely automated, whether a third-party provider hosts or accesses data, and whether the organisation offers services into the European Union must be confirmed through the final architecture, contracts and operating model. The report is an academic governance assessment, not legal advice or a formal compliance certification.

1.2 Method and evidence

The assessment combines qualitative risk identification, a 5-by-5 likelihood-and-impact risk register, a mapping to the NIST AI Risk Management Framework (AI RMF 1.0), a review of selected legal and ethical frameworks, and a reproducible synthetic-data experiment. Risk scores are calculated as likelihood multiplied by impact. The project's scoring bands are Low (1–4), Moderate (5–9), High (10–15) and Critical (16–25). Fairness and performance measures were calculated on a held-out test set. Logistic-regression coefficients and permutation importance were used as complementary interpretability evidence.

2. Ethical Risk Identification and Stakeholder Impact

The platform affects several stakeholder groups: customers and applicants; people whose identity documents or biometric information may be processed; fraud and operations staff; data-protection, compliance and risk teams; senior management; technology suppliers; auditors; and regulators. The principal ethical concern is that an incorrect or poorly governed AI output can have consequences beyond technical error. It may prevent a legitimate person from accessing a service, expose private information, delay an investigation, create an unjustified fraud suspicion or make it difficult for an affected person to challenge an outcome.

2.1 Algorithmic bias and unfair financial outcomes

Training data may not represent the population that the system will serve. Historical financial records can reflect unequal access to banking, employment, credit history or documentation. Features that appear neutral may act as proxies for socioeconomic or demographic differences. A model can therefore produce unequal error rates or selection outcomes even when a sensitive demographic field is excluded from training. In financial risk assessment, a false negative may incorrectly classify a creditworthy applicant as high risk; a false positive may fail to identify a genuinely risky case. Both errors have consequences and should be analysed separately.

2.2 Privacy, transparency and human agency

Identity verification and financial assessment may involve extensive personal information. Excessive collection, indefinite retention, secondary use or uncontrolled vendor access can undermine privacy and individual autonomy. If an AI-generated result is not explained in understandable terms, a customer may be unable to identify an incorrect input or challenge an adverse decision. Human oversight is also an ethical requirement in practice: a reviewer who

merely accepts a system recommendation without authority, time, training or information to question it does not provide meaningful oversight.

2.3 Security, reliability and accountability

Attackers may submit manipulated identity documents, spoof liveness checks, exploit APIs, poison data pipelines, steal model artefacts or extract sensitive information. Model drift and changing fraud techniques can reduce reliability after deployment. Third-party models, cloud services and data providers introduce dependencies that may be difficult to audit. Finally, incomplete logs or unclear ownership can prevent the organisation from explaining who approved a model, which version produced an output, who reviewed it and what action followed. These concerns are reflected in risks R001–R010 in the project risk register.

3. Governance and Risk Management Using NIST AI RMF

The project uses NIST AI RMF 1.0 as a voluntary risk-management framework. Its four core functions are Govern, Map, Measure and Manage. They are continuous and mutually reinforcing rather than a one-time sequence. Governance provides organisational accountability and informs the other functions. The framework is not itself a law and does not replace applicable data-protection or financial-sector obligations.

3.1 Govern

SecureFinance Africa should establish an AI governance committee with representation from business, technology, information security, privacy, legal, compliance, risk management and customer operations. Each model and use case should have an accountable business owner and a technical owner. The risk register assigns proposed accountable owners to each risk, including the Chief AI Officer for bias and transparency, Data Protection Officer for privacy, Chief Risk Officer for unfair financial decisions, Chief Information Security Officer for cybersecurity, and Chief Compliance Officer for auditability. These are proposed roles and must be formally approved and resourced.

Governance policies should define approved purposes, prohibited uses, data access, model development and change control, validation independence, incident escalation, human override authority, retention, supplier oversight and record keeping. Staff should be trained to recognise automation bias and to explain how customers can request review. Management should approve risk appetite and explicitly accept, mitigate or reject residual risks. High residual risks should not be accepted informally by a technical team.

3.2 Map

The organisation should document the system's intended purpose, users, deployment context, affected populations, data flows, suppliers and foreseeable misuse. It should map the complete decision pathway: data collection, identity checks, feature generation, model inference, staff review, customer communication, appeal and record retention. It should identify who may be harmed and how. This mapping must distinguish a fraud alert used as an investigative lead from a creditworthiness score used to determine eligibility. It must also identify whether biometric processing, profiling or solely automated decisions occur.

3.3 Measure

The Measure function requires evidence about model performance and trustworthiness. Appropriate measures include accuracy, precision, recall, F1-score, false-positive and false-negative rates, calibration, group-based selection rates, true-positive rates and false-positive rates. Tests should cover data quality, robustness, security, explainability and performance across relevant population groups. Measurements should be repeated on representative validation data and under plausible operating conditions. Thresholds should be approved before deployment rather than selected after observing favourable results.

The current experiment is an initial measurement exercise, not production validation. It excludes the demographic group from model features but retains it for group evaluation. This is useful for detecting disparities, but excluding the field does not remove proxy effects. The organisation should test alternative thresholds and features, assess confidence intervals or repeated samples, and investigate whether observed differences are practically and legally significant.

3.4 Manage

The Manage function converts identified and measured risks into prioritised actions. The risk register provides proposed controls, monitoring indicators and escalation triggers for each of the ten risks. Examples include representative-data testing and bias remediation for R001; minimisation, lawful-basis assessment, encryption and access controls for R002; appeal and correction mechanisms for R003; decision explanations for R004; mandatory human review for consequential decisions under R005; and secure development, API protection, adversarial testing and incident response for R006.

For R007, model performance and data drift should be monitored with documented retraining and rollback criteria. For R008, vendor due diligence, contractual safeguards and supplier monitoring are required. For R009, identity false-acceptance and false-rejection rates should be monitored, with manual escalation for uncertain cases. For R010, versioned model records, approval workflows and tamper-resistant audit logs should make decisions traceable. An incident process should enable containment, investigation, notification where legally required, remediation and lessons learned.

3.5 Risk-register findings

The project register contains ten risks. Inherent ratings are: seven Critical and three High. Residual ratings, assuming the proposed controls are effective, are: four High and six Moderate. The four High residual risks are R001 algorithmic bias, R002 privacy and data protection, R003 unfair financial decisions and R006 cybersecurity and adversarial attacks. These should receive priority treatment and explicit management review. The register's residual scores are estimates; no control-effectiveness testing is supplied in the current evidence. The organisation should therefore treat the residual ratings as target estimates until controls are implemented and independently tested.

4. Legal and Ethical Compliance Assessment

4.1 Nigeria Data Protection Act 2023

The Nigeria Data Protection Act 2023 is the central data-protection statute for the proposed initial Nigerian deployment, subject to confirmation of the organisation's role and processing activities.

The project's legal assessment identifies Section 24 principles for personal-data processing; Section 25 lawful basis; Sections 26–27 consent and information obligations as applicable; Section 28 Data Privacy Impact Assessment (DPIA) for processing likely to create high risk; Section 30 sensitive personal data; Sections 34–38 data-subject rights and related protections; Section 37 safeguards for certain solely automated decisions; Section 39 security; and Sections 41–43 international transfers, as applicable.

Before processing begins, the organisation should document each processing purpose, data category, data source, lawful basis, retention period, recipients and access permissions. It should collect only information necessary for the specified purpose and provide clear privacy information. A DPIA should be completed where required, especially where the nature, scale, context or purpose of processing is likely to create high risk. Biometric processing requires specific legal assessment because the relevant data may be sensitive personal data. The organisation should also establish procedures for access, correction, objection and other applicable data-subject requests.

Section 37 is particularly relevant if the platform makes a decision based solely on automated processing that produces legal or similarly significant effects. The Act provides for exceptions and requires suitable safeguards in relevant circumstances; it should not be described as an absolute ban on automated decisions. The project should provide a meaningful route to human intervention, an opportunity for the data subject to express their point of view and a way to contest the decision, where the statutory provision applies. Cross-border hosting and vendor access must be assessed against the Act's transfer requirements before data is moved or made accessible internationally.

4.2 EU Artificial Intelligence Act

The EU AI Act (Regulation (EU) 2024/1689) is binding within its applicable scope. Whether it applies to SecureFinance Africa depends on territorial reach, the role of the organisation in the AI value chain, the intended purpose and the relevant application dates. The organisation should not assume that a Nigerian deployment is automatically outside the Act if, for example, the system is placed on the EU market or its output is used in the Union. A jurisdictional assessment is required before international expansion.

The three proposed functions require separate classification. Under Annex III, point 5(b), AI systems intended to evaluate the creditworthiness of natural persons or establish their credit score are listed as high-risk, with an exception for systems used for the purpose of detecting financial fraud. A fraud-detection system used exclusively for that purpose is therefore treated differently from a creditworthiness model. Certain biometric systems also require careful distinction: verification intended solely to confirm that a specific person is who they claim to be is not the same use as remote biometric identification. The exact design and intended purpose determine classification; labels chosen by the developer are not decisive.

Where the Act applies and a system is high-risk, relevant obligations may include risk management, data governance, technical documentation, logging, transparency to deployers, human oversight, accuracy, robustness, cybersecurity, quality management and conformity assessment. The organisation should document its classification rationale and verify the current consolidated regulation and applicable dates before placing a system on the market or putting it into service. The present assessment does not claim that the platform has completed any conformity assessment.

4.3 UNESCO Recommendation on the Ethics of AI

UNESCO's Recommendation on the Ethics of Artificial Intelligence was adopted in 2021 and is a non-binding international ethical framework. It places human rights and dignity at the centre of AI governance and addresses fairness, privacy, transparency, human oversight, safety, security and accountability. SecureFinance Africa can translate these principles into practical requirements: assess impacts before deployment, test for disparate outcomes, explain consequential decisions, minimise personal data, provide human review and ensure that responsibility remains with identifiable people and organisational bodies.

4.4 OECD AI Principles

The OECD Recommendation of the Council on Artificial Intelligence was adopted in 2019 and amended in 2024. It is a recommendation, not directly binding legislation. Its principles include inclusive growth and well-being; respect for human rights, fairness and privacy; transparency and explainability; robustness, security and safety; and accountability. For this case, these principles support documented model purpose, understandable outputs, security testing, assigned risk owners, monitoring and stakeholder engagement. They complement legal obligations but do not replace them.

4.5 Consolidated compliance position

The Nigeria Data Protection Act is binding for processing within its scope. The EU AI Act is binding where its territorial and material scope applies. UNESCO and OECD provide non-binding ethical guidance. Compliance cannot be established by listing frameworks alone: it requires evidence that relevant controls are implemented, tested, monitored and updated. The existing legal-risk traceability matrix is a useful starting point, but each mapped requirement should be linked to an owner, implementation status, evidence artefact and review date.

5. Synthetic Fairness and Explainability Assessment

5.1 Dataset and experimental design

The experiment generated 1,000 synthetic applicant records using a fixed random seed. The dataset contains Age, Annual_Income, Credit_History, Debt_To_Income, Employment_Years, Demographic_Group and Actual_Eligible. Group A contains 503 records and Group B 497. Income distributions were intentionally different between groups in the generator. The eligibility label was generated from a formula based on financial and employment features, without directly including demographic group. The experiment used a 70/30 train-test split with random state 42, resulting in 700 training records and 300 test records. The model was a StandardScaler and LogisticRegression pipeline.

The demographic group was excluded from model training features and retained as a sensitive feature for evaluation. This design allows group comparisons while avoiding direct use of the group field in the model. It does not remove indirect effects: income, employment and other variables may be correlated with group membership. The synthetic labels represent the generator's assumptions, not an objective or legally validated definition of creditworthiness.

5.2 Predictive performance

Metric	Result
Accuracy	0.6833 (68.33%)

Precision	0.6926 (69.26%)
Recall	0.8942 (89.42%)
F1-score	0.7806 (78.06%)

The model's recall is relatively high, meaning it identifies a large proportion of records labelled eligible by the synthetic generator. Precision and accuracy are more moderate, indicating a meaningful level of incorrect predictions. The costs of false positives and false negatives are not necessarily equal. In a real financial context, the organisation would need to define the decision objective, quantify customer and institutional harm, calibrate thresholds and assess whether the model is appropriate for the specific use case.

5.3 Group fairness results

Metric	Group A	Group B
Selection rate	0.8153	0.8112
True-positive rate	0.8878	0.9011
False-positive rate	0.6949	0.6538
Accuracy	0.6688	0.6993
Precision	0.6797	0.7069
Recall	0.8878	0.9011
F1-score	0.7699	0.7923

The demographic parity difference is 0.0041, equivalent to a selection-rate gap of approximately 0.41 percentage points. The equal opportunity difference is 0.0133, or approximately 1.33 percentage points in true-positive rates. The equalized odds difference is 0.0411, or approximately 4.11 percentage points, reflecting the largest gap across the true-positive and false-positive rates. In this sample, selection rates and true-positive rates are close, while the false-positive rates differ more noticeably: 69.49% for Group A and 65.38% for Group B.

These values should not be interpreted as proof of fairness. They describe one model, one synthetic data-generation process, one split and one threshold. A 300-record test set may not provide stable estimates for subgroup comparisons. The organisation should report subgroup sample sizes, uncertainty intervals, repeated-split or cross-validation results, and performance at alternative thresholds. It should also assess intersectional groups where lawful and statistically appropriate. Fairness criteria can conflict, and the appropriate measure depends on the use case, harms and legal context.

5.4 Explainability results

The standardised logistic-regression coefficients were: Credit_History 0.5206; Employment_Years 0.3470; Annual_Income 0.2967; Debt_To_Income -0.2466; and Age 0.1209. Positive coefficients indicate a positive association with the model's predicted eligibility, holding other model inputs constant; the negative debt-to-income coefficient indicates a negative association. These are model associations, not causal effects or policy justifications.

Permutation importance provides a complementary view by measuring the reduction in F1 score when a feature is shuffled on the test data. Mean importance was 0.041709 for Credit_History (standard deviation 0.010898), 0.021322 for Debt_To_Income (0.009777), 0.021097 for Annual_Income (0.010401), 0.018053 for Employment_Years (0.013078) and 0.007941 for Age (0.009963). Credit history had the largest measured contribution to predictive performance. The variability estimates caution against treating small differences in ranking as definitive. Permutation importance measures predictive dependence, not causation, and correlated features can affect the result.

5.5 Fairness and explainability conclusion

The experiment demonstrates a reproducible process for measuring group outcomes and examining model behaviour. It does not validate a production lending model. Before deployment, SecureFinance Africa should use representative, lawfully collected data; verify label quality; test proxy effects; evaluate subgroup error rates; assess calibration and threshold choices; document reasons for decisions; and obtain independent validation. Customers should have accessible channels to correct inaccurate data and challenge consequential outcomes. The fairness analysis should be repeated after material model, data or operating-context changes.

6. Integrated Controls, Monitoring and Deployment Recommendation

6.1 Required controls before any pilot

The following conditions should be treated as preconditions rather than optional improvements: (1) approve a precise intended purpose and data-flow map for each function; (2) complete a documented legal assessment, lawful-basis analysis and DPIA where required; (3) complete a privacy and security architecture review; (4) validate the model on representative and lawfully sourced data; (5) conduct independent fairness, robustness and explainability testing; (6) implement meaningful human review, override and appeal processes; (7) complete vendor due diligence and contractual safeguards; (8) maintain versioned documentation and audit logs; and (9) approve monitoring thresholds, incident response and rollback plans.

6.2 Ongoing monitoring

Monitoring should include data quality and drift, model performance, group-based selection and error rates, false acceptance and rejection in identity verification, customer complaints and appeals, human override rates, security alerts, vulnerability findings, access anomalies, supplier incidents and audit-log completeness. Monitoring frequency should reflect risk and transaction volume. Material changes to data, features, thresholds, model architecture, vendors or intended purpose should trigger reassessment and approval. Escalation thresholds should be set in advance and linked to named owners and decision authority.

6.3 Deployment decision

The current evidence supports a decision of NO-GO for autonomous production decision-making. The synthetic experiment is educational evidence only; the risk register still estimates four High residual risks; and the files supplied do not demonstrate implemented control effectiveness, real-world validation, formal legal approval, or completed security testing. A limited, non-production research phase may continue using synthetic data. A controlled pilot should be considered only after the preconditions above are met, with human decisions retained and the system's role clearly bounded. Any pilot should have a defined scope, duration, success criteria, affected-user safeguards and an immediate suspension mechanism.

The organisation should not treat a low demographic-parity gap in synthetic data as a deployment clearance. Nor should it treat a completed compliance matrix as proof of compliance. Approval should be based on evidence, documented accountability and an explicit acceptance of remaining risk by authorised management. If material unexplained disparities, unlawful processing, serious vulnerabilities, unreliable identity outcomes or missing human safeguards remain, deployment should be postponed.

7. Conclusion

AI can support financial services by assisting identity checks, detecting suspicious activity and structuring risk assessments. However, these benefits are conditional on responsible design and governance. The SecureFinance Africa assessment identifies material risks to fairness, privacy, transparency, human agency, cybersecurity and accountability. The NIST AI RMF provides a practical lifecycle structure for governing, mapping, measuring and managing those risks. Nigerian data-protection law is central to the initial deployment, while the EU AI Act may become relevant depending on scope and intended purpose. UNESCO and OECD principles provide additional ethical direction.

The synthetic fairness experiment is a useful starting point, not a certification. Its results show relatively close selection and true-positive rates between the two generated groups, alongside a larger false-positive-rate difference and moderate overall accuracy. Explainability analysis identifies credit history as the strongest measured predictive feature. These findings should guide further testing, not justify automated financial decisions. The responsible course is to continue controlled validation, close governance and legal gaps, test controls independently, and preserve meaningful human accountability before any real-world deployment.

References

1. National Institute of Standards and Technology (NIST). (2023). Artificial Intelligence Risk Management Framework (AI RMF 1.0), NIST AI 100-1. https://nvlpubs.nist.gov/nistpubs/ai/NIST.AI.100-1.pdf

2. Nigeria Data Protection Act, 2023. Nigeria Data Protection Commission. https://ndpc.gov.ng/wp-content/uploads/2024/03/Nigeria_Data_Protection_Act_2023.pdf

3. European Parliament and Council. (2024). Regulation (EU) 2024/1689 laying down harmonised rules on artificial intelligence (Artificial Intelligence Act). https://eur-lex.europa.eu/eli/reg/2024/1689/oj

4. UNESCO. (2021). Recommendation on the Ethics of Artificial Intelligence. https://www.unesco.org/en/legal-affairs/recommendation-ethics-artificial-intelligence

5. OECD. (2019, amended 2024). Recommendation of the Council on Artificial Intelligence, OECD/LEGAL/0449. https://legalinstruments.oecd.org/en/instruments/OECD-LEGAL-0449

6. SecureFinance Africa case-study synthetic dataset and analysis scripts: analysis/generate_synthetic_data.py, analysis/fairness_analysis.py and analysis/explainability_analysis.py.

7. Project evidence: risk_register/ai_risk_register.csv; evidence/ndpa_compliance_matrix.csv; evidence/legal_risk_traceability.csv; evidence/analysis_notes.md; and the generated files in results/.

Appendix A. Evidence Inventory

The repository evidence supporting this report includes: the ten-row AI risk register; risk-analysis summary and residual-risk matrix; NDPA compliance matrix; legal-risk traceability matrix;

synthetic applicant dataset; synthetic-data generator; fairness-analysis script and group/overall metric exports; held-out test predictions; logistic-regression coefficient export; permutation-importance export and plot; and the experiment notes. These artefacts support reproducibility and traceability. They do not establish that proposed organisational controls have been implemented or that the model has been tested on real customers.